

PERSONAL PROJECT PORTFOLIO

CareShield: Nursing Staff Cybersecurity Awareness Campaign

Interactive Branching Scenario E-Learning Module for NHS Clinical Staff

Toochukwu Praise Ajoku

MSc Cyber Security | Keele University

Student Member, CIISec

June 2026

Target Organisation	Royal Hospital (RH) NHS Trust - nursing staff
Artefact	CareShield - 4-episode interactive branching scenario (Twine/Harlowe, deployed on Netlify)
Campaign Focus	Credential security, phishing recognition, BYOD/GDPR, incident reporting
Design Framework	NCSC/ENISA Cyber Security Culture, NIST SP 800-50 Rev. 1, ISO/IEC 27001:2022
Theoretical Basis	Compliance Budget (Beautement et al.), Human-centred security (Zimmermann et al.)
Compliance Standard	WCAG 2.1 AA, UK GDPR, NHS English Plain Language, non-punitive framing

Executive Summary

This portfolio documents the design, development, and deployment of CareShield - a mobile-optimised interactive cybersecurity awareness campaign built specifically for nursing staff at a fictional Royal Hospital NHS Trust. The project addresses a documented gap in clinical cybersecurity training: the mismatch between generic annual e-learning and the specific operational pressures that drive insecure workarounds in nursing environments.

Rather than treating nurses as the "weak link" to be corrected, CareShield adopts Zimmermann et al.'s (2024) human-centred cybersecurity framework: nurses are expert users working inside poorly aligned systems, so the campaign must address both behaviour and the system design conditions that produce insecure workarounds. This distinction has direct practical consequences - a campaign that blames users for workarounds without addressing the workflow pressures that create them will not produce sustained behavioural change (Sasse and Flechais, 2005).

The artefact is a four-episode branching scenario e-learning module built using Twine/Harlowe and deployed as a standalone HTML file. Each episode places the learner in an active decision role rather than a passive reading role, directly building security self-efficacy - identified by Malik et al. (2026) as the strongest predictor of sustained compliance under fatigue conditions. The module is completable in 3-5 minutes per episode on mobile during shift breaks, is WCAG 2.1 AA compliant, and uses NHS branding and plain English throughout.

CareShield defines five measurable outcomes across a six-month post-deployment window, evaluated against a baseline phishing simulation and SIEM credential-sharing alerts - positioning it as an evidence-based intervention rather than a compliance checkbox exercise (Karamahmutoglu and Gokturk, 2024).

Part 1: User Group Analysis and Security Challenges

1.1 Why Nursing Staff

Nursing staff were selected as the target group based on three convergent risk factors that create a uniquely challenging security environment: breadth of system access, operational time pressure, and structural incompatibility between clinical workflow and security control design.

Nurses interact with multiple clinical systems across wards - Electronic Health Records (EHR), medication dispensing, imaging, and communication platforms - each requiring independent authentication. This creates the compliance budget overload identified by Beauteament, Sasse and Wonham (2008): repeated security demands cause behavioural disengagement through cognitive overload, not indifference. The nurse who shares a login is not being careless; they are rationally prioritising patient care within a system that has made secure access operationally incompatible with clinical workflow.

Sasse and Flechais (2005) establish that security controls designed without reference to operational context predictably produce workarounds. Koppel et al. (2015) documented this directly in clinical settings, observing nurses physically marking workstations to avoid re-authentication between patient interruptions. The WannaCry attack (2017), which disabled 80 NHS trusts, originated from poor access hygiene rather than sophisticated exploitation (NAO, 2018) - demonstrating that this risk is not hypothetical.

1.2 Security Control Friction Mapping

Table 1 maps the four most consequential security controls to their usability friction, resulting workarounds, and organisational risk. This mapping is the diagnostic foundation for the campaign design - each episode directly targets one of these friction points rather than addressing generic security awareness.

Security Control	Usability Friction	Workaround	Organisational Risk
Session timeout	Re-auth during emergencies	Shared login; persistent sessions	Non-repudiation failure; GDPR breach
Password rotation	Multiple systems; frequent resets	Reuse; sticky notes	Credential compromise; lateral movement
MFA	Extra step during urgent tasks	Shared OTPs; bypass requests	Control weakened
RBAC	Access delays during transfers	Credential borrowing from colleagues	Access policy violation

1.3 Regulatory and Standards Gap

Under ISO/IEC 27001:2022 Annex A control A.6.3, organisations must provide awareness and training proportionate to role (ISO, 2022). The Royal Hospital's generic annual e-learning fails this standard by delivering Tier 1 generic awareness where NIST SP 800-50 Rev. 1 (2024) mandates Tier 2 role-based training for high-risk operational staff. NIST SP 800-53 Rev. 5 controls AT-2 and AT-3 further specify that training must be frequency-aligned and role-aligned - not simply completed once per year (NIST, 2020).

CareShield was designed to close this standards gap: it is role-specific (nursing staff only), scenario-based (not generic policy reading), frequency-appropriate (microlearning at shift change rather than annual block delivery), and measurable against defined outcomes rather than completion rate alone.

Part 2: CareShield Campaign Design

2.1 Design Philosophy

CareShield's design is grounded in Zimmermann et al.'s (2024) argument that sustainable security behaviour in clinical environments requires changing system conditions as well as individual decisions. This has two practical consequences for the campaign design:

- The campaign must not frame nurses as the problem. Punitive framing increases psychological defensiveness and reduces the likelihood that staff report near-misses - eliminating the organisational learning mechanism that makes a security culture self-improving (Zimmermann et al., 2024).
- The campaign must provide a two-way feedback mechanism. CareShield's "Report Friction" pathway lets nurses log usability barriers to IT, turning the campaign into a system improvement tool rather than a one-way compliance message.

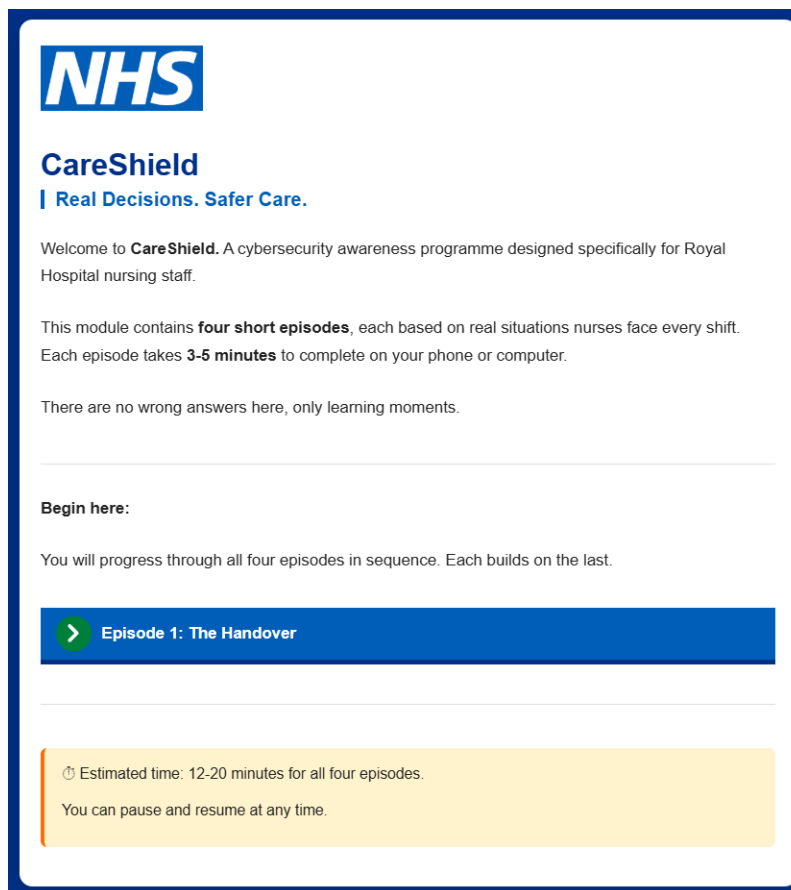


Figure 1: CareShield start screen - NHS branding (#003087), 4-episode sequential structure, progress bar, and non-punitive framing ("There are no wrong answers - only learning moments")

2.2 Root Cause Targeting

Following the NCSC/ENISA Cyber Security Culture framework (ENISA, 2018), CareShield maps five root causes to campaign components. Each episode directly addresses a specific root cause rather than delivering generic security awareness content:

Root Cause	Theoretical Basis	Campaign Response
Workflow-security conflict	Koppel et al. (2015); Sasse and Flechais (2005)	"Report Friction" pathway: nurses log usability barriers to IT
Compliance budget exhaustion	Beautement, Sasse and Wonham (2008)	3-5 minute microlearning at shift-change
Security treated as secondary	Sasse and Flechais (2005)	Teaches safe shortcuts such as emergency override
Low personal relevance	Nifakos et al. (2021)	Scenarios use RH characters, real EHR interfaces, NHS-specific phishing templates
Low psychological safety	Zimmermann et al. (2024)	Episode 4 reframes reporting as professional duty, not failure admission

2.3 The CareShield Artefact

2.3.1 Format Selection Rationale

The branching scenario format was selected over passive formats (posters, slide decks, video) because it places learners in active decision roles, directly building security self-efficacy - the strongest predictor of sustained compliance under fatigue conditions identified by Malik et al. (2026). Passive formats generate awareness; branching scenarios build the decision-making habit that produces behaviour change under operational pressure.

Phishing simulations were rejected as the sole intervention because they are diagnostic, not instructional (Malik et al., 2026): they identify who clicks malicious links but do not teach the decision process that would prevent the click. CareShield combines simulation-equivalent decision pressure with instructional feedback at each branch point.

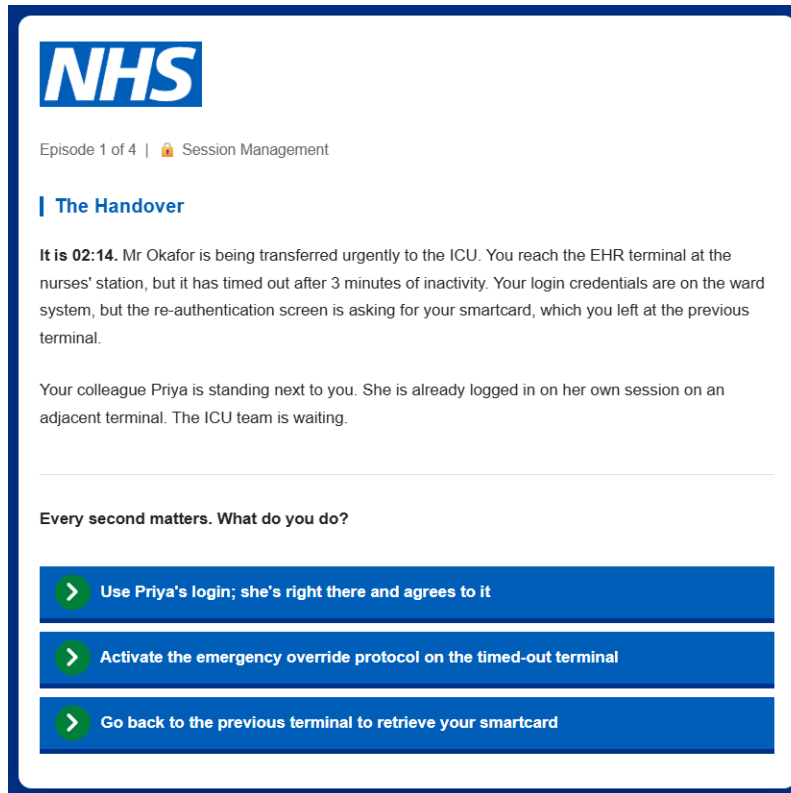


Figure 2: Episode 1 decision screen (The Handover) - three realistic branching choices under time pressure, with character context and clinical setting detail

Technical implementation: Built using Twine 2.12.0 with the Harlowe 3.3.9 format.

Deployed as a standalone HTML file - no server required, works on any device browser.

NHS branding: background #003087 (NHS Blue), responsive CSS, WCAG 2.1 AA compliant.

Mobile-optimised: tested on desktop (Windows/Chrome) and mobile (Android/Chrome).

2.3.2 Episode Structure

Episode	Scenario	Root Cause Addressed	Security Concept
1: The Handover	Session timeout during emergency patient transfer	Structural incompatibility	Session management; non-repudiation; emergency access protocol
2: The NHS Email	Fake NHS Digital email requesting urgent password verification	Time-pressure exploitation	Phishing recognition; reporting pathway
3: The WhatsApp Photo	Nurse photographs medication chart on personal phone to share with off-site GP	Compliance budget; BYOD	UK GDPR; data minimisation; approved secure channels

Episode	Scenario	Root Cause Addressed	Security Concept
4: The Near Miss	Shared terminal left logged in; visitor gains access	Psychological safety	Incident reporting; shared accountability; CQC/ICO implications

Each branch shows realistic consequences - audit logs, reporting forms, or breach implications - so the learner sees organisational impact rather than only policy language (Zimmermann et al., 2024). The "Report Friction" pathway at the completion screen links directly to a pre-filled IT request form (it.friction@royalhospital.nhs.uk) and the Datix near-miss reporting system.

2.4 Measurable Outcomes

Consistent with the NIST SP 800-50 Rev. 1 (2024) programme lifecycle (Plan-Analyse-Design-Develop-Implement-Assess), CareShield defines five measurable outcomes evaluated across a six-month post-deployment window, applying Karamahmutoglu and Gokturk's (2024) usability-security measurement methodology:

Metric	Method	Target	Horizon
Phishing click rate	Simulated NHS phishing campaign	10% or less by M6 vs Week 0 baseline	Baseline, M3, M6
Incident reporting rate	Helpdesk ticket categorisation	30% or more increase from baseline	Monthly
Module completion and retention	In-module quiz + M3 reassessment	80% or more pass; 15% or less knowledge decay	Immediate + M3
Credential-sharing events	SIEM anomaly alerts	50% reduction in shared-session events	Quarterly
Security culture perception	Anonymous ENISA survey	Shift from compliance-as-burden to compliance-as-normal	Annual

Part 3: Artefact Screenshots

3.1 Episode 1 - Consequence Screens

The following screenshots show the consequence screens from Episode 1 (The Handover), demonstrating the feedback mechanism that distinguishes CareShield from passive awareness content. Each branch choice leads to a tailored consequence screen showing the regulatory and organisational impact of the decision, not just a generic "correct/incorrect" response.

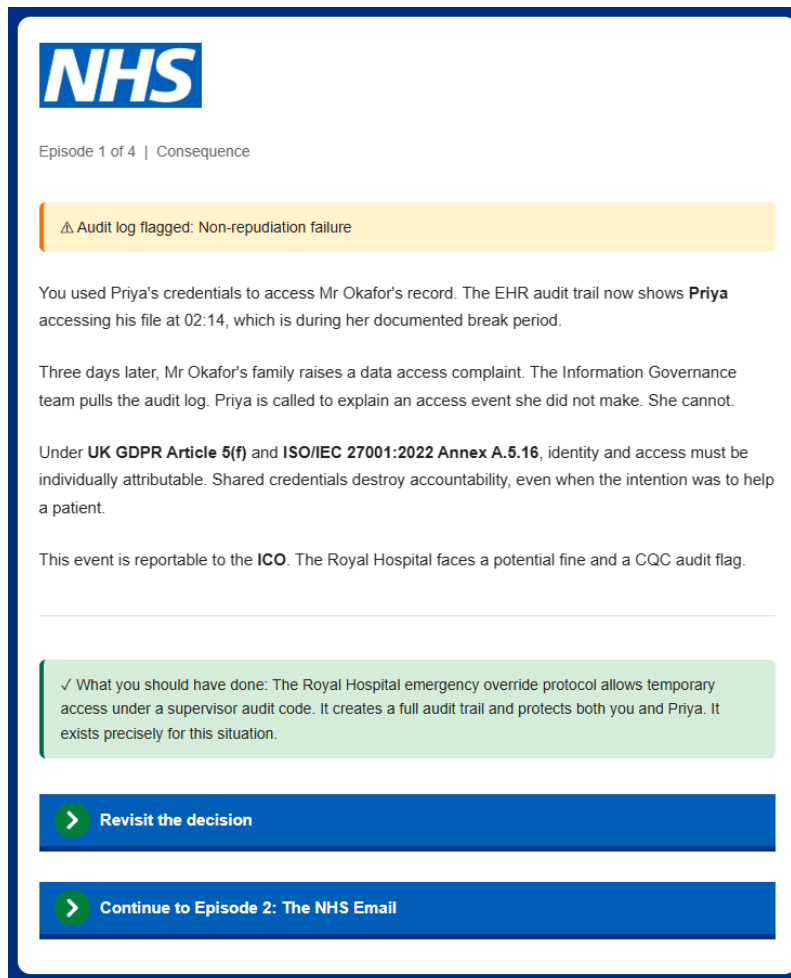


Figure 3: Episode 1 consequence screen (wrong choice - shared credentials) - warning feedback explaining non-repudiation failure, ISO/IEC 27001:2022 Annex A.5.16 violation, and mandatory ICO notification under UK GDPR Article 33

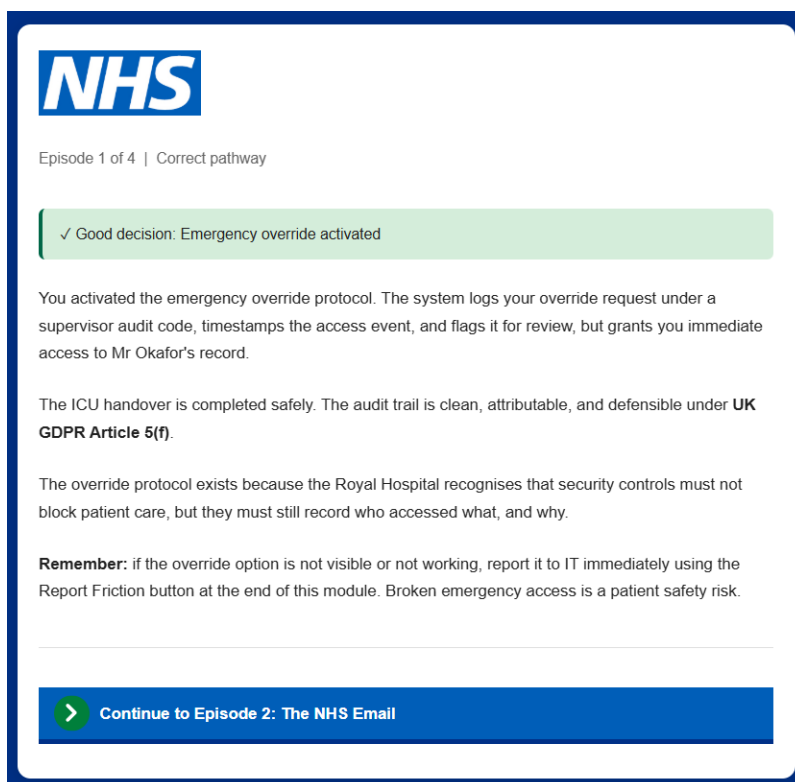


Figure 4: Episode 1 correct pathway (emergency override) - green success feedback confirming audit trail integrity under UK GDPR Article 5(f), with explanation of why the override is the clinically and legally correct choice

3.2 Episode 2 - Phishing Decision Screen

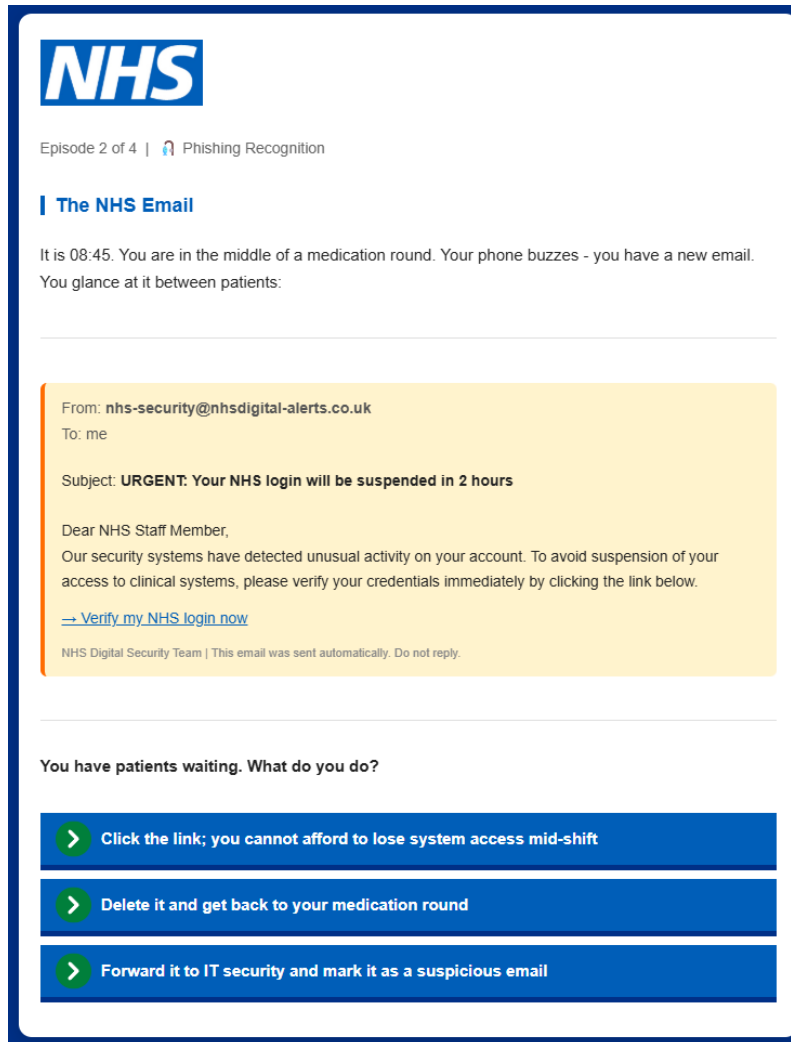


Figure 5: Episode 2 decision screen (The NHS Email) - realistic phishing email mockup using spoofed sender domain, with three choices targeting social engineering awareness and the reporting duty under NHS policy

3.3 Completion Screen

NHS

| ✓ CareShield Complete

Well done. You have completed all four CareShield episodes.

In this module you:

- ✓ Identified the correct emergency access protocol during a session timeout
- ✓ Recognised and reported an NHS-branded phishing attempt
- ✓ Protected patient data by using approved secure channels
- ✓ Reported a near-miss and contributed to a system-level improvement

Did a security control get in the way of patient care during this module or in real life on your ward?

Tell IT about it. Every report helps the Royal Hospital fix systems, not blame people.

→ Report a security control that blocked care: it.friction@royalhospital.nhs.uk

→ Report a real phishing email: it.security@royalhospital.nhs.uk

→ Report a near-miss: Datix, available on the RH intranet

CareShield is produced by the Royal Hospital Information Governance and IT Security teams in partnership with ward nursing leads. The NHS logo is used with permission for internal staff training purposes only.

Stronger security. Safer care. Thank you.

> What happens next?

Figure 6: Completion screen - four learning outcome confirmations, Report Friction pathway directing staff to it.friction@royalhospital.nhs.uk and the Datix near-miss reporting system

Report Friction mechanism: The completion screen's "Report Friction" button links to a pre-filled IT request form categorised as "Security Control Usability Issue".

This turns CareShield into a two-way improvement tool: staff report which controls are causing workarounds, and IT can use this data to prioritise UX improvements.

This directly addresses Koppel et al.'s (2015) finding that workarounds persist because staff have no channel to report the friction that creates them.

Part 4: Critical Reflection

4.1 Design Trade-offs

4.1.1 Micro-Duration vs Depth

The 3-5 minute per-episode format directly addresses the compliance budget constraint identified by Beauteament, Sasse and Wonham (2008): delivering training during shift changes rather than requiring dedicated sessions eliminates the organisational access problem that makes annual e-learning difficult to complete. However, micro-duration limits the depth of each episode - each must focus on one high-risk workaround rather than covering multiple concepts.

This trade-off was accepted deliberately. Security fatigue research (Furnell and Thomson, 2009; Malik et al., 2026) shows that cognitive overload is the primary mechanism of disengagement - a 3-minute episode that builds one decision habit is more effective than a 30-minute module that overwhelms the learner and is forgotten within weeks.

4.1.2 RH-Specific Realism vs Portability

CareShield uses Royal Hospital characters, NHS-specific phishing templates, and RH system interfaces to maximise personal relevance - identified by Nifakos et al. (2021) as a key predictor of engagement in clinical security training. The trade-off is reduced portability: the module cannot be deployed unchanged at another NHS trust without reskinning the characters and organisation-specific details.

This is the correct trade-off for the stated purpose. Generic content is less effective precisely because it lacks the specific cues that make scenarios feel real to the learner (Nifakos et al., 2021). A future version of CareShield would be architected as a template system where the scenario logic is fixed but the organisational branding and character names are configurable parameters.

4.1.3 Report Friction Mechanism and IT Responsiveness

The Report Friction mechanism creates a dependency on IT responsiveness: if staff submit usability barrier reports and receive no visible response, the mechanism actively damages trust rather than building it - staff conclude that reporting is pointless, reducing the likelihood of future near-miss reporting. This is the systemic risk identified by Zimmermann et al. (2024) for transparency-based security interventions.

In a production deployment, the Report Friction pathway would require a defined SLA for IT acknowledgement (within 5 working days), a visible backlog tracker accessible to ward managers, and a quarterly review process where security control UX improvements are communicated back to staff. Without this infrastructure, the pathway should not be activated.

4.2 Comparison with Rejected Formats

Format	Limitation	Why CareShield is better suited
Posters / infographics	Awareness only - no decision building	Branching builds decision habit under pressure, not just knowledge (Malik et al., 2026)
Phishing simulations	Diagnostic, not instructional	CareShield provides instructional feedback at each decision point
Facilitator-led workshops	Incompatible with shift patterns	Async mobile delivery at shift change; no scheduling dependency

Format	Limitation	Why CareShield is better suited
Annual e-learning modules	Generic; Tier 1 not Tier 2 standard	Role-specific; NIST 800-50 Tier 2 compliant; frequency-appropriate

4.3 UK GDPR and Governance Considerations

CareShield processes two categories of personal data that require governance controls before production deployment:

- Module completion and quiz data: records which nurse completed which episode and their quiz scores. Under UK GDPR Article 5, this must be processed under a documented lawful basis (legitimate interests or legal obligation for staff training), retained only for the period necessary, and reported only in aggregate form at ward level to protect psychological safety.
- Report Friction submissions: nurses may describe specific incidents or name colleagues in friction reports. These submissions are personal data and potentially sensitive - they must be routed to a restricted IT inbox with role-based access controls, and must not be used for performance management purposes without explicit staff consent.

A Data Protection Impact Assessment (DPIA) would be required before deployment, assessing the necessity and proportionality of both data categories. As Tambe-Jagtap (2023) notes, human-centric cybersecurity interventions that collect staff behavioural data without transparent governance create the same trust deficits they are designed to address.

4.4 Sustainability and Continuous Improvement

CareShield is designed as a living campaign rather than a one-time deployment. The measurement framework (Table 4) generates data that feeds directly back into campaign revision decisions:

- If phishing click rate does not reach 10% or less by M6, Episode 2 content is revised.
- If incident reporting rate does not increase by 30% or more by M3, Episode 4 framing is revised.
- If knowledge decay exceeds 15% at M3 reassessment, a refresher micromodule is added to the episode sequence.
- Report Friction submissions are reviewed quarterly to identify which security controls require UX redesign.

This closed-loop design reflects the NIST SP 800-50 Rev. 1 (2024) programme lifecycle principle that security awareness is a continuous improvement cycle, not a compliance event. The campaign stops when the metrics are achieved and the security culture perception survey shows the target shift - not when a calendar date is reached.

Appendix A: Full Measurement Framework

Table A1 provides the complete operational measurement framework for CareShield across a 12-month deployment window, extending the five-metric summary in Part 2.4.

Metric	Collection Method	Tool / Platform	Owner	Frequency	Decision Trigger
Phishing click rate	Simulated NHS-branded phishing email	GoPhish / KnowBe4	IT Security	Pre, M3, M6, M12	Over 10% at M6 triggers mandatory refresher
Phishing report rate	Count of emails reported via button	Same as above	IT Security	Per wave	Under 20% triggers Episode 2 redesign
Module completion	LMS completion tracking	Moodle / NHS e-learning	Training Lead	Monthly	Under 80% in 30 days triggers manager follow-up
Knowledge retention	Quiz now + repeat at M3	LMS quiz engine	Training Lead	Immediate + M3	Over 15% decay triggers refresher module
Credential-sharing events	Simultaneous login correlation rule	Splunk / Elastic	SOC Analyst	Quarterly	No improvement after M6 triggers SSO review
Incident reporting volume	Near-miss reports through RH portal	Datix	Info Governance	Monthly	No increase at M3 triggers Episode 4 revision
Security culture perception	Anonymous ENISA-style survey	MS Forms / SurveyMonkey	Info Governance	Pre + M12	No shift triggers ward focus groups
Usability friction score	Post-module 5-item burden survey	Embedded in LMS	Training Lead	Per completion	High burden persists triggers IT redesign meeting

Data protection note: individual results from phishing simulations or module completion should be processed under the RH data protection framework and reported only in aggregate form at ward level. This protects psychological safety and supports honest reporting behaviour.

References

Beaument, A., Sasse, M. A. and Wonham, M. (2008) "The compliance budget: Managing security behaviour in organisations," in Proceedings of NSPW 2008, pp. 47-58. Available at: <https://discovery.ucl.ac.uk/1301853/>

European Union Agency for Cybersecurity (ENISA) (2018) Cybersecurity Culture Guidelines: Behavioural Aspects of Cybersecurity. Athens: ENISA. Available at: <https://www.enisa.europa.eu/publications/cybersecurity-culture-guidelines-behavioural-aspects-of-cybersecurity>

Furnell, S. and Thomson, K. L. (2009) "Recognising and addressing security fatigue," Computer Fraud and Security, 2009(11), pp. 7-11. Available at: <https://ro.ecu.edu.au/ecuworks/371/>

International Organization for Standardization (2022) Information Security Management Systems - Requirements, ISO/IEC 27001:2022. Geneva: ISO. Available at: <https://www.iso.org/standard/27001>

Karamahmutoglu, I. and Gokturk, M. (2024) "A systematic approach to measure usability and security trade-off," in Proceedings of HORA 2024, Istanbul, pp. 1-6. Available at: <https://www.semanticscholar.org/paper/A-Systematic-Approach-to-Measure-Usability-and-Karamahmutoglu-Gokturk/c1874efe2cb29d9ffe71e57ca09af9e956cfc4c5>

Koppel, R., Smith, S., Blythe, J. and Kothari, V. (2015) "Workarounds to computer access in healthcare organisations: You want my password or a dead patient?" in Proceedings of HCI and Usable Privacy and Security Workshop, pp. 215-220. Available at: <https://www.cs.dartmouth.edu/~sws/pubs/ksbk15-draft.pdf>

Malik, A., Goel, S. and Sinha, S. (2026) "Security fatigue: Manifestation of emotional exhaustion and cynicism by depletion of self-regulation capacity," European Journal of Information Systems, pp. 1-20. Available at: <https://doi.org/10.1080/0960085x.2026.2621809>

National Audit Office (2018) Investigation: WannaCry cyber attack and the NHS. London: NAO, HC 414. Available at: <https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/>

National Institute of Standards and Technology (2020) Security and Privacy Controls for Information Systems and Organizations, NIST SP 800-53 Rev. 5. Gaithersburg, MD: NIST. Available at: <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology (2024) Building a Cybersecurity and Privacy Learning Program, NIST SP 800-50 Rev. 1. Gaithersburg, MD: NIST. Available at: <https://doi.org/10.6028/NIST.SP.800-50r1>

Nifakos, S. et al. (2021) "Influence of human factors on cyber security within healthcare organisations: A systematic review," Sensors, 21(15), p. 5119. Available at: <https://doi.org/10.3390/s21155119>

Sasse, M. A. and Flechais, I. (2005) "Usable security: Why do we need it? How do we get it?" in Security and Usability. Sebastopol, CA: O'Reilly Media, pp. 13-30. Available at: <https://discovery.ucl.ac.uk/id/eprint/20345/>

Tambe-Jagtap, S. N. (2023) "Human-centric cybersecurity: Understanding and mitigating the role of human error in cyber incidents," SHIFRA, 2(1), pp. 1-12.

Zimmermann, V. et al. (2024) "Human-centered cybersecurity revisited: From enemies to partners," Communications of the ACM, 67(11), pp. 72-81. Available at: <https://doi.org/10.1145/3665665>